POLÍTICA DE SEGURIDAD Y PRIVACIDAD DE LA INFORMACIÓN

Sistema transaccional Hotel Reservas

Proceso de seguridad de la información y protección de datos personales

GUSTAVO ADOLFO CARDONA BAYONA
JONATHAN SOLER GUEVARA
HUGO ANDRÉS FORERO ANGEL

INGENIERÍA DE SOFTWARE, UNIVERSIDAD MANUELA BELTRÁN
SISTEMAS TRANSACCIONALES A1

Docente: Jamilton Fernando Benvides

Versión 1.0 · Bogotá D.C., 14 de noviembre de 2026

Versión	Fecha	Descripción del cambio
1.0	2026-11-14	Adopción de la política, el aviso de privacidad y el procedimiento de habeas data; implementación en la APK 0.9.3, la API y el script 09.

1. Introducción

Hotel Reservas es un sistema transaccional móvil para la gestión de reservas de un hotel pequeño o mediano. Para cumplir su función recoge y conserva datos personales de los huéspedes (nombre, tipo y número de documento, teléfono y correo), registra pagos y comprobantes, y expone un asistente de consultas y un servicio de predicción basados en inteligencia artificial. La información que administra es, por tanto, un activo cuya pérdida, alteración, consulta o uso no autorizados afectaría a los huéspedes, al hotel y a la confianza en el sistema.

Esta política adopta para el proyecto los lineamientos de la Política General de Seguridad de la Información del Departamento Administrativo de la Función Pública, versión 02 (2026), tomada como modelo de referencia por su alineación con la norma ISO/IEC 27001:2022 y con el Modelo de Seguridad y Privacidad de la Información, y los concreta en controles verificables sobre la aplicación móvil, la API REST, la base de datos SQL Server y los servicios de inteligencia artificial. Las obligaciones específicas provienen de la Ley 1266 de 2008 y de la Ley 1581 de 2012, cuyos textos se incorporan como fuentes del asistente de cumplimiento descrito en la sección 9.

2. Glosario

Activo de información: dato, sistema, servicio o documento con valor para el hotel; en este proyecto, la base de datos HotelReservas, la API, la aplicación móvil, los servicios inteligentes y la documentación.

Dato personal: cualquier información vinculada o que pueda asociarse a una persona natural determinada o determinable (Ley 1581 de 2012, artículo 3, literal c).

Titular: persona natural cuyos datos personales son objeto de tratamiento; en el sistema, el huésped (Ley 1581 de 2012, artículo 3, literal f).

Responsable del tratamiento: quien decide sobre la base de datos y el tratamiento; el hotel, representado por el administrador del sistema (artículo 3, literal e).

Encargado del tratamiento: quien realiza el tratamiento por cuenta del responsable; los servicios externos de inteligencia artificial y el servicio inteligente de predicción (artículo 3, literal d).

Tratamiento: cualquier operación sobre datos personales, como la recolección, almacenamiento, uso, circulación o supresión (artículo 3, literal g).

Confidencialidad, integridad y disponibilidad: propiedades de la información que la política protege; corresponden a los principios de la Ley 1266 de 2008, artículo 4, y a los objetivos de la ISO/IEC 27001.

Política, estándar, guía y procedimiento: en el sentido del glosario del modelo de referencia; esta política fija las declaraciones de alto nivel y los controles obligatorios, y los procedimientos del repositorio (scripts, LEEME y pruebas) describen cómo se ejecutan.

3. Propósito

Dar a conocer a los integrantes del equipo, al docente, al personal del hotel y a los huéspedes la forma en que Hotel Reservas protege la información, en particular los datos personales, aplicando los principios de seguridad de la información y las leyes colombianas que obligan a quien administra bases de datos personales, y dejar evidencia verificable de cada control en el propio sistema.

4. Objetivo

Garantizar la confidencialidad, la integridad y la disponibilidad de la información que administra Hotel Reservas, y los derechos de los titulares de los datos personales, mediante una política, controles técnicos y procedimentales implementados en la aplicación, la API y la base de datos, y una auditoría que permita verificar su cumplimiento y mejorarla.

4.1 Objetivos secundarios

- Proteger los datos de los huéspedes y del personal en cada capa del sistema.
- Minimizar el riesgo de acceso no autorizado, pérdida o alteración de la información, y de divulgación de datos personales, incluida la que podría producirse a través de los servicios de inteligencia artificial.
- Asegurar que el titular pueda ejercer sus derechos de conocer, actualizar, rectificar, revocar y suprimir sus datos desde la aplicación.
- Cumplir los requisitos legales y dejar evidencia de ese cumplimiento en la bitácora de reservas y en la auditoría de seguridad.
- Fortalecer la cultura de seguridad del equipo y del personal del hotel.

5. Audiencia

Los integrantes del equipo de desarrollo, el docente de la asignatura, el administrador y los recepcionistas del hotel que operan el sistema, y los huéspedes, que consultan el aviso de privacidad desde la pantalla de inicio de sesión de la aplicación y en el repositorio del proyecto.

6. Alcance

La política aplica a todos los componentes del sistema: la aplicación Android (prototipo integrado en Android Studio), la API REST HotelReservas.Api, la base de datos SQL Server HotelReservas, el servicio inteligente de predicción (TensorFlow y FastAPI), el servicio inteligente de seguridad de la información (servicio_seguridad_ia), el asistente de consultas con Azure OpenAI y el repositorio GitHub. Cubre los procesos de reservar, pagar, hacer check-in y check-out, cancelar, administrar usuarios y clientes, consultar al asistente, predecir el riesgo de cancelación y atender las solicitudes de habeas data.

7. Marco legal

La política se sustenta en las siguientes normas, citadas en los controles de las secciones 9 y 14 al nivel de artículo.

Norma	Contenido aplicable	Dónde se aplica en el sistema
Constitución Política, artículo 15	Derecho a la intimidad y habeas data: conocer, actualizar y rectificar la información recogida en bases de datos.	Pantalla Mis datos; recurso /api/habeasdata.
Ley 1266 de 2008 (habeas data)	Artículo 4: principios de veracidad, finalidad, circulación restringida, temporalidad, seguridad y confidencialidad. Artículo 6: derechos de los titulares. Artículo 7: deberes de los operadores. Artículo 8: deberes de las fuentes. Artículo 9: deberes de los usuarios. Artículo 16: peticiones, consultas y reclamos.	Perfiles con token, enmascaramiento, auditoría, consultas y reclamos con estado "en trámite".
Ley 1581 de 2012 (protección de datos)	Artículo 4: principios. Artículo 5: datos sensibles. Artículo 7: menores. Artículo 8: derechos del titular. Artículo 9: autorización. Artículo 12: deber de informar. Artículo 13: personas a quienes se puede suministrar la información. Artículos 14 y 15: consultas y reclamos. Artículo 17: deberes del responsable. Artículo 18: deberes del encargado. Artículo 26: transferencia internacional.	Casilla de autorización con fecha; aviso de privacidad; catálogo por perfil; filtro de datos personales hacia el modelo de IA; plazos de respuesta.
Decreto 1377 de 2013 (compilado en el Decreto 1074 de 2015)	Artículo 5: autorización por cualquier medio que permita su consulta posterior. Artículo 9: revocatoria. Artículo 13: política de tratamiento.	HUESPED.autorizacion_datos y fecha_autorizacion; botón Revocar autorización; este documento.
Ley 1273 de 2009 (delitos informáticos)	Artículos 269A (acceso abusivo), 269C (interceptación) y 269F (violación de datos personales).	Bloqueo tras cinco intentos, HTTPS, auditoría de accesos, mínimo privilegio.
Ley 527 de 1999	Artículos 5, 6 y 10: validez y fuerza probatoria de los mensajes de datos.	Comprobantes, bitácora y auditoría de seguridad como evidencia.
ISO/IEC 27001:2022 y Modelo de Seguridad y Privacidad de la Información (Decreto 1078 de 2015)	Sistema de gestión de seguridad de la información: política, roles, controles de acceso, registro de eventos, gestión de incidentes y mejora continua.	Estructura de esta política, roles de la sección 12 y revisión de la sección 14.

8. Política general de seguridad de la información

El equipo de Hotel Reservas, consciente de la importancia de la información que el sistema administra, se compromete con los huéspedes, el personal del hotel y la Universidad a cumplir los principios de confidencialidad, integridad y disponibilidad mediante la gestión de los riesgos de seguridad, la implementación de controles técnicos y procedimentales en cada capa del sistema, el cumplimiento de los requisitos legales y reglamentarios, en particular la protección de los datos personales, y la continuidad del servicio de reservas. La integridad de la información es además el núcleo del sistema: la transacción de confirmación de reserva se ejecuta con bloqueo y registro en bitácora para que nunca existan dos reservas sobre la misma habitación y las mismas fechas.

El administrador del hotel, como responsable de la seguridad de la información, se compromete a implementar, operar y mejorar de forma continua los controles de esta política, a mantener la auditoría de seguridad y a atender las solicitudes de los titulares en los plazos de la ley.

9. Políticas específicas y controles implementados

9.1 Control de acceso y autenticación

Todo acceso al sistema exige un usuario individual con contraseña y un token JWT que lleva el perfil (administrador, recepcionista o cliente). Las contraseñas se almacenan únicamente como hash PBKDF2-SHA256 con sal y cien mil iteraciones; nunca en texto claro. La política de contraseñas exige mínimo ocho caracteres con mayúscula, minúscula, número y símbolo, sin espacios y distinta de las claves comunes; la API la verifica en el registro de clientes, en el cambio de contraseña y en la utilidad de hash del administrador. Tras cinco intentos fallidos la cuenta se bloquea durante quince minutos (USUARIO.bloqueado_hasta) y el hecho queda en la auditoría; la sesión de la aplicación se cierra a los diez minutos sin actividad. Cada perfil accede solo a lo necesario: el cliente ve únicamente sus reservas y sus datos.

9.2 Tratamiento de datos personales

Solo se recogen los datos necesarios para la finalidad del servicio: nombre, tipo y número de documento, teléfono y correo. No se recogen datos sensibles (Ley 1581 de 2012, artículos 5 y 6). Antes de registrar a un huésped se obtiene su autorización previa, expresa e informada (artículo 9; Decreto 1377 de 2013, artículo 5), con el aviso de privacidad del anexo A, y se conserva la fecha en HUESPED.fecha_autorizacion. Los huéspedes menores de edad se registran únicamente con autorización del adulto responsable de la reserva (artículo 7). Los datos circulan de forma restringida: el personal los ve enmascarados en las listas (vista vw_huesped_enmascarado), no se entregan a terceros salvo obligación legal (tarjeta de registro de alojamiento y reportes a Migración Colombia) y se conservan solo el tiempo que exigen las normas tributarias y de archivo.

9.3 Derechos de los titulares (habeas data)

El titular ejerce gratuitamente sus derechos desde la pantalla Mis datos de la aplicación o por el correo del hotel: consulta de la información que el hotel tiene de él, actualización y rectificación, revocatoria de la autorización y solicitud de supresión. Las consultas se responden en máximo diez días hábiles y los reclamos en máximo quince (Ley 1581 de 2012, artículos 14 y 15; Ley 1266 de 2008, artículo 16). Cada solicitud queda en la tabla SOLICITUD_HABEAS_DATA con su fecha límite y estado; la supresión se ejecuta con el procedimiento sp_SuprimirDatosHuesped, que anonimiza el registro cuando el huésped no tiene reservas vigentes y conserva los comprobantes por la obligación tributaria.

9.4 Inteligencia artificial y transferencia de datos

El asistente de consultas interpreta y redacta; la API ejecuta y conserva el control de las transacciones. Antes de enviar cualquier consulta al modelo de lenguaje, la API aplica el filtro de datos personales, que retira documentos, teléfonos y correos, y registra el evento DATO_FILTRADO_IA cuando lo hace. El modelo solo puede invocar funciones de solo lectura del catálogo correspondiente al perfil, y el perfil cliente solo dispone de disponibilidad, tarifa y sus propias reservas. Como el servicio de Azure OpenAI opera fuera del país, el filtro garantiza que no se transfieren datos personales (Ley 1581 de 2012, artículo 26) y la política de no entrenamiento del proveedor evita que las consultas se usen para entrenar modelos (artículo 18). El servicio inteligente de predicción y el servicio inteligente de seguridad se ejecutan en la infraestructura del hotel y no envían datos a terceros.

9.5 Registro de eventos y auditoría

La bitácora de reservas registra quién cambió cada estado y cuándo; la auditoría de seguridad (tabla AUDITORIA_SEGURIDAD) registra los inicios de sesión exitosos y fallidos, los bloqueos, los cierres de sesión, las solicitudes de habeas data, los datos filtrados hacia la IA, los cambios de contraseña y los accesos denegados, con la dirección IP y sin datos personales en el detalle. El administrador consulta ambas desde la aplicación (pestaña Seguridad) y la API (/api/habeasdata/auditoria). Los registros se conservan al menos un año.

9.6 Comunicaciones y configuración segura

La aplicación se comunica con la API por HTTPS; la API responde con cabeceras de seguridad (X-Content-Type-Options, X-Frame-Options, Referrer-Policy, Cache-Control: no-store y HSTS). Las claves del correo del hotel, del token JWT y de Azure OpenAI se guardan fuera del código (dotnet user-secrets o variables de entorno) y nunca en la aplicación móvil ni en el repositorio.

9.7 Respaldo, continuidad e incidentes

La base de datos se respalda diariamente con copia completa y el respaldo se verifica restaurándolo una vez al mes. Ante un incidente (acceso no autorizado, pérdida o divulgación de datos), el administrador bloquea las cuentas afectadas, conserva la auditoría, informa a los titulares cuando sus datos se vieron comprometidos y, si aplica, a la Superintendencia de

Industria y Comercio (Ley 1581 de 2012, artículo 17, literal n), y registra el análisis y las acciones correctivas. La aplicación conserva un modo de demostración sin servidor que permite mostrar el sistema aunque la API no esté disponible.

10. Aplicabilidad

La política aplica a los integrantes del equipo de desarrollo, al administrador y a los recepcionistas del hotel, a los clientes que se registran en la aplicación y a los proveedores de servicios de inteligencia artificial y de nube, en todas las actividades de recolección, consulta, uso, intercambio y conservación de información del sistema. Su incumplimiento tiene las consecuencias de la sección 13.

11. Compromisos y responsabilidades

El equipo se compromete a implementar, mantener y mejorar los controles de esta política, a documentar cada cambio en el repositorio y a verificar su funcionamiento con las pruebas automáticas y las evidencias de la sección 14. Todo usuario del sistema es responsable de proteger la información a la que accede y de reportar al administrador cualquier incidente o situación que pueda comprometerla.

12. Roles y responsabilidades

Rol	Responsabilidades
Administrador del hotel (responsable del tratamiento y oficial de seguridad)	Aprueba y mantiene la política; crea y desactiva usuarios; define los parámetros de seguridad (intentos, inactividad, plazo de pago); revisa la auditoría de seguridad; atiende y resuelve las solicitudes de habeas data en los plazos de la ley; inscribe la base de datos en el Registro Nacional de Bases de Datos cuando aplique; gestiona los incidentes.
Recepcionista (usuario de la información)	Registra la autorización del huésped antes de crear su registro; usa los datos solo para la reserva; no copia ni comparte datos fuera del sistema; cierra la sesión al terminar; reporta incidentes.
Cliente (titular)	Custodia su contraseña; mantiene actualizados sus datos; ejerce sus derechos desde Mis datos.
Equipo de desarrollo (Gustavo Cardona, Jonathan Soler, Hugo Forero)	Implementa y prueba los controles técnicos; no incluye secretos en el código; aplica el filtro de datos personales en cualquier integración nueva; documenta los cambios en el repositorio.
Proveedores de IA y nube (encargados)	Tratan únicamente los datos filtrados que reciben, conforme a sus términos de no entrenamiento y a las instrucciones del responsable.
Docente de la asignatura (control y verificación)	Audita el cumplimiento en las sustentaciones y revisa las evidencias.

13. Sanciones

El incumplimiento de esta política por parte del personal del hotel conlleva la desactivación de la cuenta y las consecuencias disciplinarias y laborales que correspondan; el acceso abusivo, la interceptación o la divulgación de datos personales pueden constituir los delitos de los artículos 269A, 269C y 269F de la Ley 1273 de 2009, y el incumplimiento de las obligaciones de protección de datos puede dar lugar a las sanciones de los artículos 23 y 24 de la Ley 1581 de 2012, impuestas por la Superintendencia de Industria y Comercio. Para los integrantes del equipo aplican las normas académicas de la Universidad.

14. Cumplimiento y verificación

Cada control tiene una evidencia verificable en el repositorio o en el sistema en ejecución. La política se revisa al cierre de cada fase del proyecto y, en operación, al menos una vez al año o cuando cambie la normativa.

Control	Norma	Evidencia
Contraseñas con PBKDF2 y política de complejidad	Ley 1266 art. 4; Ley 1581 art. 4 lit. g; RNF01	Seguridad/Seguridad.cs y PoliticaContrasenas; registro en la APK; prueba "Contraseña débil/fuerte" del servicio de seguridad
Bloqueo tras cinco intentos fallidos	Ley 1273 art. 269A	ControlIntentos; USUARIO.intentos_fallidos y bloqueado_hasta; evento BLOQUEO en la auditoría
Cierre de sesión por inactividad	Política, numeral 9.1	APK: SEG.inactividadMin; evento SESION_EXPIRADA
Autorización de datos con fecha y aviso de privacidad	Ley 1581 arts. 9 y 12; Decreto 1377 art. 5	HUESPED.autorizacion_datos; casilla en registro y nueva reserva; anexo A
Derechos del titular	Ley 1581 arts. 8, 14 y 15; Ley 1266 arts. 6 y 16; Decreto 1377 art. 9	Pantalla Mis datos; /api/habeasdata; SOLICITUD_HABEAS_DATA; sp_SuprimirDatosHuesped
Filtro de datos personales hacia la IA y catálogo por perfil	Ley 1581 arts. 18 y 26	FiltroDatosPersonales; evento DATO_FILTRADO_IA; CatalogoFunciones.ParaRol
Asistente de cumplimiento normativo	Ley 1266 y Ley 1581 (base de conocimiento)	servicio_seguridad_ia: 36 artículos, 14 pruebas automáticas en pruebas/evidencias.json
Auditoría de seguridad	Ley 1581 art. 17; política, numeral 9.5	Tabla AUDITORIA_SEGURIDAD; pestaña Seguridad de la APK; /api/habeasdata/auditoria
Enmascaramiento para el personal	Ley 1581 art. 4 lit. f; Ley 1266 art. 9	Vista vw_huesped_enmascarado; clase Enmascarar
Cabeceras de seguridad y secretos fuera del código	Política, numeral 9.6	CabecerasSeguridad; dotnet user-secrets

Anexo A. Aviso de privacidad

Responsable: Hotel Reservas, correo hotelreservas2026@gmail.com. Finalidad: gestionar sus reservas, pagos, comprobantes y notificaciones, y cumplir la tarjeta de registro de alojamiento y los reportes exigidos por la ley de turismo y de migración. Datos que se recogen: nombre, tipo y número de documento, teléfono y correo; no se recogen datos sensibles. Sus derechos: conocer, actualizar y rectificar sus datos, revocar la autorización, solicitar la supresión y presentar reclamos ante la Superintendencia de Industria y Comercio (Ley 1581 de 2012, artículo 8; Ley 1266 de 2008, artículo 6). Los ejerce en la pantalla Mis datos de la aplicación o escribiendo al correo del hotel; las consultas se atienden en diez días hábiles y los reclamos en quince. Seguridad: sus datos se protegen con contraseñas cifradas, acceso por perfil, bloqueo de intentos, cierre de sesión por inactividad, auditoría de accesos y un filtro que impide que sus documentos, teléfonos y correos lleguen al modelo de inteligencia artificial. Al marcar la casilla "Autorizo el tratamiento de mis datos personales" usted acepta este aviso.

Anexo B. Procedimiento de atención de solicitudes de habeas data

1. El titular presenta la solicitud desde Mis datos (consulta, rectificación, revocatoria o supresión) o por el correo del hotel; la API la registra en SOLICITUD_HABEAS_DATA con fecha y fecha límite (diez días hábiles para consultas, quince para reclamos).

2. La consulta y la rectificación se resuelven en línea; la revocatoria se aplica de inmediato y las reservas vigentes se conservan por la relación contractual.

3. La supresión queda en trámite; el administrador la ejecuta desde la pestaña Seguridad con sp_SuprimirDatosHuesped cuando el huésped no tiene reservas vigentes. El procedimiento anonimiza el registro, desactiva la cuenta y conserva los comprobantes por la obligación tributaria.

4. Si la solicitud no puede atenderse en el plazo, se informa al titular el motivo y la nueva fecha, que no supera los ocho días hábiles adicionales (Ley 1581 de 2012, artículo 15).

5. Toda solicitud y su respuesta quedan en AUDITORIA_SEGURIDAD como evidencia.

Referencias

Congreso de la República de Colombia. (2008). Ley 1266 de 2008, por la cual se dictan las disposiciones generales del hábeas data. Diario Oficial, 47219.

Congreso de la República de Colombia. (2009). Ley 1273 de 2009, por medio de la cual se modifica el Código Penal y se crea el bien jurídico de la protección de la información y de los datos. Diario Oficial, 47223.

Congreso de la República de Colombia. (2012). Ley 1581 de 2012, por la cual se dictan disposiciones generales para la protección de datos personales. Diario Oficial, 48587.

Departamento Administrativo de la Función Pública. (2026). Política General de Seguridad de la Información, versión 02. Proceso de Seguridad de la Información.

Presidencia de la República de Colombia. (2013). Decreto 1377 de 2013, por el cual se reglamenta parcialmente la Ley 1581 de 2012. Diario Oficial, 48834.

ISO/IEC. (2022). ISO/IEC 27001:2022. Information security, cybersecurity and privacy protection. Information security management systems. Requirements.